

Understanding and Avoiding Phishing: A Practical Guide

This presentation explains what phishing is, shows common attack types and real-world examples, and gives clear, actionable steps you and your organisation can use to spot and stop scams. Designed for employees and the general public, it emphasises practical behaviour changes, verification practices and reporting procedures.



What Is Phishing?

Phishing is a form of social engineering where an attacker impersonates a trusted person or organisation to trick you into revealing credentials, financial data, or personal information. It arrives via email, SMS (smishing), phone calls (vishing), fake websites, or messaging apps. Crucially, the attacker often does not break into your computer – they manipulate you into taking an action that gives them access.

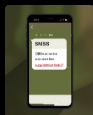


Common Types of Phishing Attacks



Email Phishing

Mass or targeted emails that mimic banks, services or colleagues to get logins or payments.



Smishing

Text messages that persuade you to click a link or reveal verification codes.



Vishing

Phone calls where the attacker pretends to be support, IT or a bank to extract information.



Whaling / CEO Fraud

Highly targeted attacks against senior staff to authorise transfers or share sensitive data.



Clone Phishing and Pharming

Clone phishing copies a legitimate message but swaps links; pharming redirects users to fake sites even when the URL looks correct.

All these approaches rely on deception and emotional triggers rather than technical exploits alone.



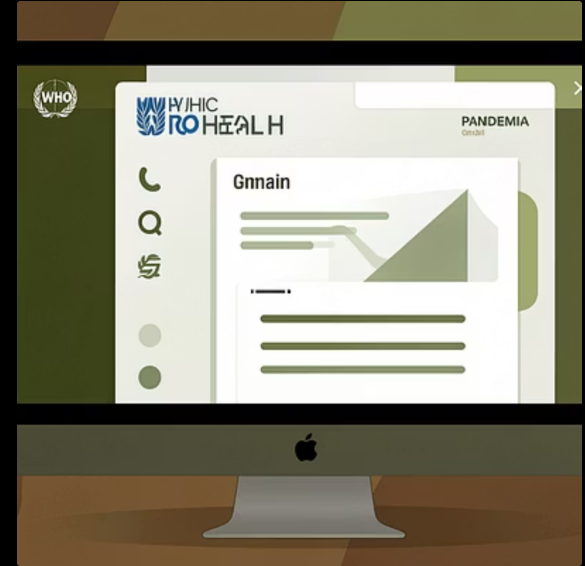
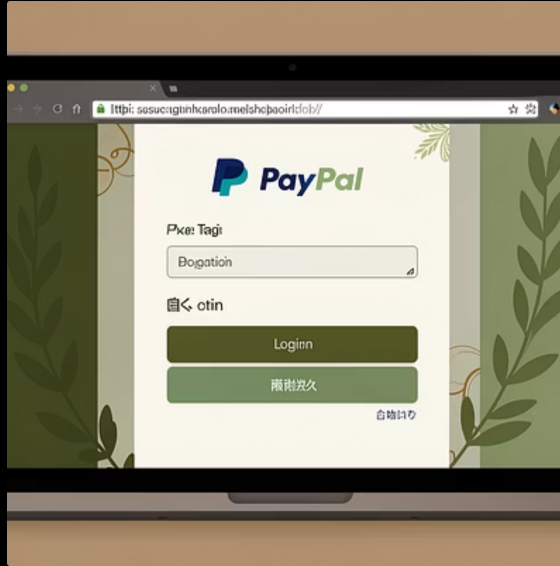
Social Engineering: How Attackers Manipulate People

Social engineering exploits emotions and expectations. Common tactics include:

- Fear – "Your account will be closed"
- Urgency – "Act within 24 hours"
- Authority – "From IT / your CEO"
- Greed – "You have won a prize"
- Trust – using logos or familiar formatting

Recognising these emotional cues is the first defence: slow down, verify, and avoid making hasty decisions under pressure.

Real-World Examples and Lessons



Notable incidents:

- 2013-2015: Fake supplier invoices tricked global companies (Google, Facebook) into paying >\$100M – lesson: independent supplier verification is essential.
- PayPal-themed phishing pages captured login credentials – lesson: never follow links in unsolicited emails; navigate directly.
- COVID-19 scams used WHO branding to spread malware – lesson: high-profile events are exploited; treat urgent health alerts with verification.

How to Spot a Phishing Message

1. Check the sender

Look at the full email address (not just the display name).
Small character swaps (l → 1, o → 0) are common.

2. Hover links

Hover (or long-press on mobile) to preview the real URL before clicking. If it looks odd, don't click.

3. Watch for mistakes

Spelling, odd grammar, or inconsistent branding are red flags.

4. Beware of urgency

Messages demanding immediate action are designed to short-circuit your scrutiny.

5. Verify requests for credentials

Reputable organisations never ask for passwords via email. Check for HTTPS but remember it is not a guarantee of safety.



Practical Protections: What You Should Do

Quick Defensive Steps

- Enable Two-Factor Authentication (2FA) on all important accounts.
- Type web addresses manually; avoid links in unsolicited messages.
- Keep devices and apps updated to fix security flaws.

Additional Best Practice

- Use reputable antivirus and email filters to block threats automatically.
- Never share passwords or verification codes by email or SMS.
- If unsure, call the organisation using a trusted number – not the one in the message.



When You Find a Suspected Phish

If you suspect a phishing message: do not click links, do not reply, and do not forward it to others. Instead:

1. Report it immediately to your IT or security team using the official channel.
3. Delete the message once reported, or quarantine it if instructed.
5. If you entered credentials, change the password immediately and enable 2FA; inform IT so they can check for unauthorised access.
7. For potential financial fraud, contact your bank immediately and monitor accounts.



If the message impersonates an executive asking for money, treat it as high-risk: verify by phone using a known number before acting.

Interactive Quiz: Test Your Awareness

1

Q1 – Suspicious Sender

You receive an email from support@amaz0n.com saying your order is delayed. What should you do?

The correct action: Do not click anything. The sender address is fake (amaz0n). Navigate to the retailer's site manually or contact support using official channels.

2

Q2 – HTTPS Safety

True or False – HTTPS means a website is completely safe.

Answer: False. HTTPS encrypts traffic, but phishing sites can also use HTTPS. Always verify the domain and context.

3

Q3 – Boss Asks for Gift Cards

Your boss emails you urgently to buy gift cards and send the codes. What is this?

Answer: Whaling or CEO fraud – verify by calling the boss on a known number before taking action.

4

Q4 – Safest Response

What is the safest thing to do when you receive a suspicious email?

Answer: Delete it and report it to your security team; do not click links or reply.

5

Q5 – SMS Prize

You receive an SMS: "Win an iPhone, click here." What is this?

Answer: Smishing – delete and do not follow the link.

Key Takeaways

1

1. Pause and verify

Don't act on urgent requests without checking the source.

2

2. Use strong protections

Enable 2FA, keep software updated and use reputable security tools.

3

3. Report promptly

Send suspected phishing to your IT/security team immediately.

4

4. Practice vigilance

Run regular training and simulated phish tests for all staff.

